MIS0611403 System Auditing & Maintenance

Model Question Paper: 4 Sets with Easy Answers Total marks per set: 10 (Q1 = 2, Q2 = 4, Q3 = 4). Based on your 4 suggestion topics, the slides (Lecture 03) and the merged PDF.

PART 1: QUESTION PAPER

Set A

1. What is audit risk? Name its three components. **(2)**
2. Explain any four risks associated with Distributed Data Processing (DDP). **(4)**
3. Explain the three objectives of audit trails. Also write the two types of audit logs. **(4)**

Set B

1. What is internal control? Write any two internal control objectives. **(2)**
2. Describe four risks and controls associated with the computer center. **(4)**
3. What is a Denial of Service (DoS) attack? Explain SYN flood and smurf attacks. **(4)**

Set C

1. Differentiate between the flat file approach and the database approach (any two points). **(2)**
2. Explain the five components of the COSO internal control framework. **(4)**
3. Explain the four operating system security components. **(4)**

Set D

1. Differentiate between external auditors and internal auditors (any two points). **(2)**
2. What is a Disaster Recovery Plan (DRP)? Explain its four features and the second-site backup options. **(4)**
3. Explain backup controls in the flat file system (GPC) and in the database environment. **(4)**

More Important Questions (practice list)

- Explain the PDC (Preventive, Detective, Corrective) control model.

- Why must incompatible IT functions be separated? Explain with examples.
- Compare centralized and distributed IT structures. How can DDP be controlled?
- IP spoofing, DDoS and how to control network risks (firewalls).
- Network-level versus application-level firewalls.
- Password control: reusable password versus one-time password.
- Malicious programs (virus, worm, logic bomb, Trojan horse, back door) and their controls.
- Partitioned versus replicated databases; deadlock and concurrency control.
- Database views (internal, conceptual, user), DBMS features, data models.
- Database access controls and their audit procedures.

PART 2: ANSWERS (easy and simple)

Set A: Answers

Q1. What is audit risk? Name its three components. (2)

Audit risk is the chance that the auditor gives a clean (unqualified) opinion on financial statements that are actually wrong (materially misstated).

Its three components are:

1. **Inherent risk**: risk that exists because of the nature of the business, even if there are no controls.
2. **Control risk**: risk that the company's internal controls will fail to prevent or catch an error.
3. **Detection risk**: risk that the auditor's own tests will fail to find the error.

Model: **Audit Risk = Inherent Risk × Control Risk × Detection Risk**

Q2. Risks associated with DDP (any four). (4)

DDP means splitting the central IT function into small IT units controlled by end users. Its risks are:

1. **Inefficient use of resources**: users may mismanage IT resources, build the same system again and again (data redundancy), and buy incompatible hardware and software.
2. **Destruction of audit trails**: transaction and master files sit on user computers. A user can delete or corrupt a file by mistake and the audit trail is lost.

3. **Inadequate segregation of duties**: with few staff, one person may do incompatible tasks, which breaks internal control.
4. **Difficulty hiring qualified professionals**: end-user managers cannot easily attract skilled IT staff, so programming errors and system failures increase.
5. **Lack of standards**: rules for development, documentation, language and purchasing may be applied unevenly or not at all.

Q3. Objectives and types of audit trails. (4)

Audit trails are logs that record activity at the system, application and user level.

Three objectives:

1. **Detecting unauthorized access**: finds hacking attempts either in real time or later by reviewing the logs.
2. **Reconstructing events**: helps trace the steps that led to a system failure or security breach, so the cause can be found and repeated incidents prevented.
3. **Personal accountability**: users know their actions are recorded, so they are less likely to misuse the system. Actions can be linked to a specific person.

Two types of logs: (i) **Keystroke monitoring**: records every key pressed and the system's response (like a telephone wiretap, so privacy issues arise); (ii) **Event monitoring**: records user IDs, session time, programs run and files or resources used.

Set B: Answers

Q1. Internal control and its objectives. (2)

Internal control is a process carried out by the board, management and other staff to give reasonable assurance that the organization achieves its goals in three areas: effective and efficient operations, reliable financial reporting, and compliance with laws and regulations.

Any two objectives: (1) safeguard assets of the firm; (2) ensure accuracy and reliability of accounting records and information; (3) promote efficiency in operations; (4) measure compliance with management's policies.

Q2. Computer center risks and controls (any four). (4)

1. **Physical location**: keep it away from hazards such as flood plains, airports, gas mains and high-crime areas, to reduce disaster risk.
2. **Construction**: a single-storey, solid building with underground power and phone lines, windows that do not open, and an air filtration system.

3. **Access**: only operators and staff who work there may enter.
4. **Air conditioning**: keep temperature at about 70–75°F and humidity near 50%, otherwise hardware logic errors can occur.
5. **Fire suppression**: alarms, automatic and manual extinguishers, sound construction and clearly marked exits.
6. **Fault tolerance**: the system keeps working if one part fails. Examples: **RAID** (redundant disks rebuild lost data) and **UPS** (backup power during power failure).

Q3. DoS attack, SYN flood and smurf attack. (4)

DoS attack: an attack on a web server that makes it unavailable to real users by flooding it with fake traffic or requests. It blocks customer transactions and hurts business.

SYN flood attack: a normal connection uses a three-way handshake: client sends SYN, server replies SYN-ACK, client sends ACK. In a SYN flood the attacker sends many SYN requests but never sends the final ACK. The server is left with many half-open connections, its ports fill up, and real users are blocked. It is hard to trace because attackers hide their identity using IP spoofing.

Smurf attack: it involves three parties: the attacker, an intermediary network, and the victim. The attacker sends spoofed ping requests (using the victim's IP address) to the intermediary network's broadcast address. Every computer there replies to the victim at once, flooding it. Control: disable broadcast addressing at the firewall.

Set C: Answers

Q1. Flat file versus database approach (any two). (2)

Point	Flat file approach	Database approach
Data ownership	Each user owns separate files (single-user view)	One shared database for all users
Redundancy	High; same data stored many times	Low; each data item stored once
Updating	Every copy must be updated manually	Update once, instantly seen by all
Data currency	Some users may see old data	All users see current data

Q2. COSO framework: five components. (4)

1. **Control environment**: the foundation. It includes integrity and ethical values, management's philosophy, organization structure and the board's attitude toward control.
2. **Risk assessment**: identifying and analyzing risks that may stop the company from reaching its objectives.
3. **Information and communication**: capturing and sharing the right information at the right time, so people can do their duties.
4. **Monitoring**: checking the quality of controls over time through ongoing reviews and separate evaluations.
5. **Control activities**: policies and procedures that make sure management's instructions are carried out (for example authorization, segregation of duties, supervision, and IT controls).

Q3. Operating system security components. (4)

1. **Log-on procedure**: the OS's first line of defense. The user enters a valid ID and password, which are checked against the authorized user database. Error messages should not reveal which one was wrong, and the user is locked out after a few failed attempts.
2. **Access token**: after a successful log-on, the OS creates a token holding the user ID, group and privileges. It is used to approve every action during that session.
3. **Access control list (ACL)**: attached to each resource (file, program, printer). It lists which users may access it and with what rights.
4. **Discretionary access privileges**: in distributed systems, the resource owner can give access rights (read-only or read-and-write) to other users. This must be closely supervised to avoid security breaches.

Set D: Answers

Q1. External versus internal auditors (any two). (2)

1. External auditors are outsiders who are independent of the organization; internal auditors are employees who represent the organization.
2. External auditors give an opinion on financial statements for outside users; internal auditors review controls and operations for management.
3. Independent internal auditors can collect evidence all year and help external auditors, which makes the external audit faster and cheaper. If internal auditors report to the controller, they lack independence and external auditors cannot rely on their work.

Q2. DRP, its four features and second-site backup. (4)

A **Disaster Recovery Plan (DRP)** is a complete statement of all actions to be taken before, during and after any disaster.

Four features:

1. **Identify critical applications**: decide which applications are needed for short-term survival (such as those that protect cash flow). This is a business decision, not only an IT decision.
2. **Create a disaster recovery team**: experts with clear duties so there is no delay or duplication.
3. **Provide second-site backup**: a duplicate processing facility.
4. **Specify backup and off-site storage procedures**: back up the OS, applications, data files, documentation and supplies, and keep them off-site.

Second-site backup options: (a) **Mutual aid pact**: two organizations agree to help each other; (b) **Empty shell (cold site)**: a building ready to receive hardware after a disaster; (c) **Recovery operations center (hot site)**: a fully equipped data center shared by many companies; (d) **Internally provided backup**: extra capacity within the organization's own centers.

Q3. Backup controls: flat file and database. (4)

Flat file system:

- **GPC (Grandparent–Parent–Child)** for sequential files: the parent file plus the transaction file produces the child file. In the next cycle the child becomes the parent and the old parent becomes the grandparent. If the current file is lost, use the latest backup and reprocess the transaction files.
- **Direct access files**: values are changed in place (destructive replacement), so the file must be copied before it is updated.
- **Off-site storage** for all backups.

Database environment (risky because one error can affect all users):

- **Backup**: automatic copy of the whole database at least once a day, stored remotely.
- **Transaction log (journal)**: audit trail of all processed transactions.
- **Checkpoint**: system pauses, reconciles logs with the database, and can restart from here after a failure.
- **Recovery module**: uses logs and backups to restart the system.

Quick Answers: Extra Important Questions

PDC control model: Preventive controls stop problems before they happen (passwords, segregation of duties). **Detective** controls find problems that have occurred (audit trails, reconciliations). **Corrective** controls fix the problem and recover (backups, error correction, recovery team). Best control is preventive, as it is cheapest.

Why separate incompatible IT functions: if one person can both develop a system and run it, they could change programs during execution without leaving a trace. So systems development, computer operations, database administration (DBA) and maintenance must be kept separate. If new development and maintenance are given to the same programmer, it causes poor documentation and program fraud, because the programmer can hide or switch off fraudulent code during audits.

How to control DDP: set up a corporate IT function, central testing of hardware and software, user services (help desk), a standards-setting body, and personnel review by the corporate group.

IP spoofing: the attacker changes the source IP address to look like a trusted source and bypass security (for example a fake order from a “real” customer). **DDoS:** a DoS attack launched from thousands of infected computers (bots or zombies, forming a botnet), so it is stronger and harder to trace.

Network-level versus application-level firewall: network-level uses screening routers to filter by source and destination address; it is fast but less secure and does not authenticate users. Application-level uses proxy applications, authenticates users, and gives detailed logs; it is more secure but slower.

Reusable versus one-time password: a reusable password is set once and reused, so weak or guessable ones are easily cracked. A one-time password changes constantly (smart card generates a new one about every 60 seconds, used with a PIN), so an intercepted password is useless.

Partitioned versus replicated database: *Partitioned*: the database is split and each site stores its own part; faster local processing and better disaster recovery, but works best when little data is shared and deadlock can occur. *Replicated*: the same data is copied at every site; fast read access and high availability, but it is hard to keep all copies consistent, so concurrency control (time-stamping and serialization) is needed.

Three database views: *Internal (physical) view*: how data is physically stored; only one. *Conceptual (schema) view*: the logical view of the whole database; only one. *User (subschema) view*: the part of the database a user is allowed to see; many.

Database access controls: user views, database authorization table (read, insert, modify, delete), user-defined procedures, encryption, biometric devices and inference controls.

Good luck with your exam! If you want more sets, an MCQ set, or a PDF/Word version, just tell me.